Threat Modeling in the Transmission of Results of an Electronic Election Using the STRIDE Model *

Vicente Ferreira Júnior[1,2], Nayara Oliveira Sales[1,2], Francis Reiner Maia Martins[1,3]. Luiz Antônio Ribeiro Júnior[1,2]

[1]University of Brasília (UnB)
CEP (Brazilian Postal Code) 70910-900 – Brasília – DF – Brazil

[2]Professional Postgraduate Program in Electrical Engineering

[3]Postgraduate Program in Applied Computing

juniorvf@gmail.com

Abstract. *Electronic elections are recurrent targets of disinformation campaigns and cyberattacks, requiring resilience mechanisms to ensure integrity, availability, and confidentiality. This paper delineates and models threats in the results transmission phase of an electronic election. The method adopts a qualitative and exploratory approach combined with bibliometric analysis using the Web of Science and Scopus databases. The bibliometrix/Biblioshiny package and the R programming language are employed to consolidate the literature and group publications into thematic clusters. The results provide a structured overview of the literature on threats to electronic voting systems. Critical security requirements for the transmission phase are identified, guided by the principles of integrity, availability, and confidentiality. The study proposes a threat catalog associated with the logical architecture and trust boundaries, with threats organized according to the STRIDE categories. The main contribution is a set of security requirements and a structured threat catalog to support secure system design, audits, and to strengthen public trust in electronic elections. In addition, the proposed catalog provides an operational mapping between assets, STRIDE categories, and security controls, supporting requirements definition, testing, and audit activities in real-world environments.*

1. Introduction

Electronic elections are part of a sociotechnical ecosystem composed of voting equipment, communication networks, aggregation and tabulation systems, and services operated by multiple public and private actors. In different jurisdictions, this ecosystem has come to be treated as critical infrastructure, since security failures may compromise the legitimacy of the democratic process [U.S. Congress 2023]. Beyond technical risks, public perceptions of vulnerability may be amplified by availability incidents and disinformation campaigns, making cybersecurity a central component of electoral governance [{FBI} and {CISA} 2024].

The *e-voting* literature has advanced in protocols and mechanisms aimed at privacy, verifiability, and resistance to coercion [Sarker et al. 2020, Lueks et al. 2020,

*The authors thank the teams of the Information Technology Secretariat of the Superior Electoral Court for the technical and institutional support provided in the development of this work.

Koitmae et al. 2021]. However, the **results transmission** phase is still often treated as a secure channel or merely as a networking detail. This simplification underestimates trust boundaries, telecommunications dependencies, and intermediate points of compromise. In architectures that combine dedicated links, public networks, VPNs, and outsourced infrastructures, this may conceal a relevant attack surface. As a result, the integrity, availability, and reliability of the electoral process may be directly affected.

In addition to classical security challenges, the results transmission phase exhibits characteristics of distributed networks and systems, with geographically dispersed nodes, heterogeneous links, and dependence on cloud infrastructure, making it subject to variable latency, partial failures, and an expanded attack surface for availability and integrity risks. In this context, threat modeling should explicitly incorporate vulnerabilities inherent to distributed environments, a phenomenon also observed in 5G/IoT scenarios with large numbers of devices and complex traffic [Silva et al. 2025].

This article addresses the following research problem: *how to systematically identify and structure cyber threats affecting the transmission of results in electronic elections, using the STRIDE model as a reference*? To answer this question, the study: (i) delineates the operational scope of transmission; (ii) describes a reference logical architecture with trust boundaries; (iii) consolidates critical assets and requirements guided by integrity, availability, and confidentiality; and (iv) derives a synthetic catalog of threats and mitigations, organized according to STRIDE [Shostack 2014]. Beyond delineating transmission as a distributed-network subsystem, the practical contribution of this work is an actionable, traceable catalog that supports requirements engineering, test planning, and audit preparation in real-world settings. Compared to prior *e-voting* threat-modeling studies, the novelty lies in the operational focus on results transmission and in the direct mapping to controls applicable in practice.

The remainder of this paper is organized as follows. Section 2 summarizes the foundations of electoral cybersecurity, threat modeling, and STRIDE. Section 3 presents the methodology and modeling procedure. Section 4 describes the logical architecture and trust boundaries. Section 5 consolidates critical assets and requirements. Section 6 presents the STRIDE threat catalog and associated mitigations. Finally, Sections 7 and 8 discuss the implications and summarize the conclusions.

2. Theoretical Background

2.1. Cybersecurity and the Electronic Electoral Process

Electoral cybersecurity involves protecting assets and processes against malicious actions that may affect the confidentiality, integrity, availability, and legitimacy of elections. Institutional reports highlight the recurrence of availability attacks and digital extortion, as well as the role of coordinated campaigns in amplifying fraud narratives [{FBI} and {CISA} 2024, Agência Brasileira de Inteligência (ABIN) 2025]. ENISA recommends a risk management approach throughout the system life cycle, with explicit identification of critical assets and security requirements [Ryan et al. 2019].

In results transmission, the integrity and authenticity of messages and evidence play a central role. Interception, tampering, replay, and denial-of-service attacks may degrade process reliability, either by compromising data or by causing large-scale operational delays. At the same time, protecting operational metadata can help reduce infrastructure exposure and limit disinformation vectors.

2.2. Threat Modeling and STRIDE

Threat modeling is a structured technique for identifying and describing threats based on architectural decomposition, data flows, trust boundaries, and security requirements [Shostack 2014]. The STRIDE model classifies threats into six categories (Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, and Elevation of Privilege) and is widely used in distributed architectures [Shostack 2014, Olaf Saßnick et al. 2024, Angganegara et al. 2025].

2.3. Applications of STRIDE in Emerging Domains

Although originally proposed as a practical model for deriving threats from data flow diagrams, STRIDE has been applied in emerging and highly regulated domains, such as industrial systems, the Internet of Things, and distributed architectures. Recent reviews indicate that decomposition into spoofing, tampering, repudiation, information disclosure, denial of service, and privilege escalation helps identify revalidation points and transform architectural analysis into a traceable threat catalog [Olaf Saßnick et al. 2024, Zhu et al. 2021]. This aspect is particularly relevant in systems with multiple boundaries and heterogeneous integrations.

In distributed infrastructures, STRIDE has been used to structure threats related to API abuse, authentication inconsistencies between services, message manipulation, and availability attacks at integration layers. In solutions supported by *blockchain* and *cloud* services, the model provides a basis for discussing vectors such as key exposure, misconfigured access policies, and dependency exploitation, with emphasis on identity mitigations and audit trails [Lencse 2020, Albert Mondong et al. 2024, Bhole et al. 2025].

2.4. Security in Electronic Voting Systems

Electronic voting (*e-voting*) systems operate in a sociotechnical environment in which technical requirements (integrity, availability, and auditability) coexist with operational pressures, high public exposure, and disinformation risks. Sectoral guidelines recommend treating the electoral ecosystem as critical infrastructure, incorporating network controls, credentials, supply chain security, auditing, and incident response [Ryan et al. 2019]. In this context, adversaries may combine technical exploitation with informational manipulation, amplifying perceived impact even when technical damage is limited.

In the results transmission phase, risk is intensified by the simultaneous need for timeliness, high event volume, and multiple boundaries (polling stations, transport networks, central systems, and, eventually, public *cloud* services). Incidents at this stage may degrade pipeline availability or raise doubts about artifact authenticity, directly affecting public trust and contestation of the process [{FBI} and {CISA} 2024, Agência Brasileira de Inteligência (ABIN) 2025]. Therefore, threat modeling for transmission should emphasize mechanisms for authenticity, chain of custody, resilience, and observability.

2.5. Related Work and Research Gaps

The literature closest to this study can be grouped into two lines. The first line comprises *e-voting* studies that discuss security properties, architectural weaknesses, or threat analysis in election systems [De Faveri et al. 2016, Risnanto et al. 2021, Sarker et al. 2020, Lueks et al. 2020, Koitmae et al. 2021]. These contributions are important because they

clarify election-specific requirements such as privacy, verifiability, coercion resistance, integrity, and trust. However, they usually treat the communication stage as a supporting mechanism within the broader voting workflow rather than as the primary analytical object. Consequently, the transmission chain is often abstracted as a secure channel or reduced to generic assumptions about authenticated communication.

The second line is composed of STRIDE-oriented studies in adjacent critical domains, including industrial control systems, IoT/CPS, network transition technologies, cloud/blockchain-based infrastructures, and risk-oriented modeling workflows [Lencse 2020, Olaf Saßnick et al. 2024, Zhu et al. 2021, Bhole et al. 2025, Albert Mondong et al. 2024, Angganegara et al. 2025]. These studies provide strong methodological references: they make architecture explicit, identify assets and boundaries, and derive threats in a reproducible way. Nevertheless, they are not specialized for the electoral domain and therefore do not directly address election-specific constraints such as chain of custody for results, public scrutiny, operational timing windows, and contestation risks in highly exposed democratic processes.

To make these distinctions explicit, Table 1 compares representative studies according to five technical criteria emphasized by the reviewers: analytical scope, threat-modeling method, analyzed assets, explicit treatment of trust boundaries, and type of validation. The comparison shows that prior work typically satisfies only part of the combination targeted in this paper. Election-centered studies contribute domain knowledge but do not provide an architecture-centered STRIDE catalog for results transmission; adjacent-domain STRIDE studies provide methodological rigor but are not tailored to election workflows.

A more detailed reading of the closest *e-voting* studies clarifies the scientific gap addressed here. De Faveri et al. [De Faveri et al. 2016] are relevant because they connect security requirements, threat reasoning, and design support for election systems. However, their contribution is centered on a modeling language for secure development, not on an explicit decomposition of the results transmission chain into flows, channels, and trust boundaries. Risnanto et al. [Risnanto et al. 2021] organize threats and countermeasures for *e-voting* at the system level, but the treatment remains broader than the transmission subsystem and does not produce a STRIDE-based catalog anchored in a reference architecture.

Likewise, protocol-centered studies such as VOTEAGAIN [Lueks et al. 2020] and related online-voting proposals [Koitmae et al. 2021] make substantial contributions to privacy, coercion resistance, and correctness. Yet their unit of analysis is the cryptographic protocol and the voter-facing workflow. They do not systematically examine operational transmission assets such as transport links, aggregation services, evidence repositories, message queues, monitoring services, or cross-boundary integrations, all of which are decisive in production-grade electoral infrastructures.

By contrast, the adjacent STRIDE literature demonstrates methodological practices that are directly useful for this paper. Al-Azzawi and Lencse [Lencse 2020] show how network functions and communication paths can be decomposed into concrete STRIDE threats; Zhu et al. [Zhu et al. 2021] illustrate how distributed IoT/cloud infrastructures can be tied to explicit assets and prioritization criteria; Mondong et al. [Albert Mondong et al. 2024] and Bhole et al. [Bhole et al. 2025] reinforce the value of linking threats to controls, implementation concerns, and critical dependencies; and the review by Sasnick et al. [Olaf Saßnick et al. 2024] shows that STRIDE remains effective in highly regulated and

Study	Scope of analysis	Threat model / method	Main assets analyzed	Explicit trust boundaries?	Validation type
De Faveri et al. [De Faveri et al. 2016]	Secure development support for e-voting systems	Security modeling language (EVSec), requirements and risk reasoning	Voting-system components and security requirements	Partial	Conceptual / design-oriented
Risnanto et al. [Risnanto et al. 2021]	Threats and vulnerabilities in e-voting systems at a broad level	Threat/vulnerability mapping with security controls	Election-system components, votes, infrastructure, controls	Limited	Analytical discussion / qualitative assessment
Lueks et al. [Lueks et al. 2020]	Coercion-resistant remote e-voting protocol	Formal protocol/security analysis	Credentials, ballots, cryptographic workflow	No (focus on protocol rather than architecture)	Formal / protocol-oriented evaluation
Koitmäe et al. [Koitmae et al. 2021]	Online voting with voter feedback and privacy considerations	Protocol/system design discussion	Voter interactions, ballots, privacy-preserving mechanisms	No	Design / argument-based
Al-Azzawi and Lencse [Lencse 2020]	IPv6 transition infrastructure (464XLAT)	STRIDE over network architecture	Network functions, packets, gateways, communication flows	Yes	Architectural analysis
Zhu et al. [Zhu et al. 2021]	IoT/CPS risk assessment	STRIDE + AHP + Bayesian network	Devices, gateways, cloud services, data flows	Yes	Quantitative prioritization / case-based
Sasnick et al. [Olaf Saßnick et al. 2024]	STRIDE in industrial/control environments	Systematic STRIDE-based review/adaptation	Industrial assets, control flows, safety-related components	Yes	Literature-based synthesis
Mondong et al. [Albert Mondong et al. 2025]	Blockchain-based distributed architecture	STRIDE with architecture-driven analysis	On-chain/off-chain services, keys, transactions, APIs	Yes	Automated testing / implementation-oriented
Bhole et al. [Bhole et al. 2025]	Critical networked infrastructure	STRIDE combined with risk/impact reasoning	Services, communication links, critical dependencies	Yes	Methodological / case-oriented
This study	**Results transmission stage in electronic elections**	**Architecture-centered STRIDE catalog informed by literature review and asset/requirement tracing**	**Results files, evidence, credentials, channels, reception services, audit trails, queues, contingency artifacts**	**Yes — explicit boundaries between source, transport, reception/aggregation, and central services**	**Traceable qualitative validation through requirements, assets, and controls**

Table 1. Technical comparison between representative related studies and this paper.

safety-relevant environments. Still, these studies address industrial, IoT, network, or blockchain settings rather than election workflows.

Therefore, the gap is not the absence of either election-security research or STRIDE-based threat modeling taken separately. The gap lies in their incomplete intersection: there is still limited literature that *simultaneously* (i) delimits the **results transmission** stage as the primary unit of analysis in electronic elections, (ii) inventories the **assets and channels** involved in that stage, (iii) makes **trust boundaries** explicit, and (iv) derives a **structured STRIDE catalog** that can be traced to security requirements, controls, and audit evidence. This paper advances the state of the art by addressing precisely this intersection, positioning results transmission not as a generic communication assumption, but as a critical and analyzable subsystem of the electoral process.

2.6. Literature Review – State of the Art

To situate this study, we surveyed peer-reviewed Web of Science and Scopus literature on threat modeling and cybersecurity in electronic voting, with emphasis on results transmission. The review indicates that most work addresses threat modeling broadly, while fewer studies explicitly detail transmission assets, flows, and trust boundaries.

Table 2 summarizes the distribution of the consolidated corpus by data source and thematic cluster, reinforcing the opportunity for an architecture-aware STRIDE catalog

that supports requirements derivation and auditability.

The relatively small number of documents in the 'electronic voting' cluster (89), compared to 'threat modeling' (446), reinforces the opportunity to tailor general techniques such as STRIDE to election-specific subsystems such as results transmission.

Thematic cluster	Web of Science	Scopus	Total
threat modeling	316	130	446
electronic voting or e-voting	53	36	89
network security	34	16	50
blockchain	29	11	40
risk assessment	17	13	30
Unclassified	19	7	26
Grand total	468	213	681

Table 2. Distribution of documents by data source (Web of Science and Scopus) and thematic cluster.

2.7. From bibliometric clusters to requirements and threats (traceability)

To address the traceability gap between the bibliometric review and the threat modeling outcomes, we explicitly mapped the dominant topics observed in the consolidated corpus to (i) transmission-stage assets, (ii) derived security requirements, and (iii) the STRIDE categories used in the catalog. In practice, this mapping was performed by reviewing the most frequent terms and abstracts in each thematic cluster and consolidating recurring security concerns into requirement statements.

Table 3 summarizes this evidence-to-requirement-to-STRIDE linkage. This mapping serves as an explicit bridge between the state-of-the-art organization (bibliometric clustering) and the architectural STRIDE analysis, reinforcing how the review informed the prioritization of integrity, availability, confidentiality, and auditability requirements for results transmission.

Evidence from the literature (cluster/topic)	Typical concerns observed in the corpus	Derived requirement(s) for results transmission	STRIDE
threat modeling / network security	Identity at boundaries, trust boundaries, abuse of exposed APIs, message manipulation, audit trails	Explicit trust boundaries; strong authentication/authorization; request correlation IDs and immutable audit trails	S, R, E
risk assessment	Operational impact, prioritization by critical assets and failure points, continuity planning	Risk-based prioritization (critical assets + boundary crossings); resilience targets (RTO/RPO), monitoring and incident response	D, R
electronic voting / e-voting	Integrity of results, authenticity, chain of custody, timeliness under peak load, public trust	End-to-end integrity (signatures/hashes); provenance metadata; verifiable chain of custody; controlled dissemination	T, R, I
blockchain / auditability (when applicable)	Tamper evidence, traceability, integrity proofs, verifiability narratives	Append-only evidence store when applicable; integrity verification at multiple stages; separation of duties	T, R

Table 3. Traceability between bibliometric evidence (topics/clusters), the derived security requirements for results transmission, and the STRIDE categories used in the threat catalog.

3. Methodology

This research is applied, exploratory, and descriptive, with a predominantly qualitative approach. As supporting evidence, a bibliometric analysis was used to consolidate and organize recent literature (2020–2025) from Web of Science and Scopus, processed with *bibliometrix*/Biblioshiny [Aria and Cuccurullo 2017]. The consolidated corpus comprises

681 documents, after metadata harmonization and duplicate removal through R scripts [R Core Team 2025]. To maintain focus, the bibliometric analysis is used only to delimit and organize the state of the art, without detailing metrics or rankings.

Threat modeling was conducted in six stages: scoping and assumptions, definition of a reference logical architecture, identification of critical assets and channels, derivation of security requirements, systematic application of STRIDE, and consolidation of threats and mitigations into a traceable catalog.

In addition to the systematic identification of threats using STRIDE, a risk-oriented prioritization criterion was adopted. In particular, threats associated with assets classified as critical in Table 4 and with flows crossing relevant trust boundaries in the architecture were prioritized. These points concentrate higher potential operational and institutional impact and are therefore more relevant for requirements definition, testing, and auditing purposes.

3.1. Adopted modeling procedure

The procedure was structured to produce a traceable and reproducible threat catalog, aligned with the assets of the results transmission stage and the trust boundaries:

1. **Scope delimitation**: definition of the transmission stage (source, transmission client, transport, reception/aggregation, and external integrations), as well as operational assumptions and involved actors.
2. **Architectural decomposition**: The Data Flow Diagram (DFD), following the STRIDE notation, was produced using `Excalidraw`, a web-based collaborative vector drawing platform [Excalidraw Team 2024]. The diagram represents processes, data stores, and flows, emphasizing channels (e.g., HTTPS), persistence (databases and repositories), and asynchronous messaging (queues and events).
3. **Trust boundaries**: explicit marking of transitions among the Internet, private network, and *cloud* services, considering that each boundary crossing requires revalidation of identity, integrity, and authorization.
4. **Asset and requirement inventory**: identification of critical artifacts (results media, metadata, credentials, evidence, and messages), qualitatively classifying the properties of integrity (I), availability (A), and confidentiality (C).
5. **Threat elicitation**: application of STRIDE to flows and components, prioritizing highly coupled points, URL issuance/consumption, metadata persistence, and event-driven processing.
6. **Correlation and mitigation**: association of threats with impacted assets and controls (cryptographic, identity-related, engineering, and operational), aiming to support auditing and governance.

3.2. Corpus construction and bibliographic support

The literature review supported the identification of recurring requirements (e.g., authenticity, chain of custody, audit trails, and resilience to unavailability) and the selection of typical controls in critical systems. Corpus consolidation combined Web of Science and Scopus and thematic grouping by term co-occurrence, following the workflow supported by `bibliometrix/Biblioshiny` [Aria and Cuccurullo 2017]. This reinforces the rationale for the requirements, without replacing the architectural analysis, which remains the primary basis for eliciting threats via STRIDE, and further justifies focusing on results transmission as an underexplored yet high-impact stage in e-voting workflows.

3.3. Use of Generative AI Tools

This study employed generative AI exclusively in the initial workflow for producing the system data flow diagram, based on automated reading of the code repository of the application's development version. All AI-assisted artifacts underwent mandatory human review, including verification, correction, and approval, before being used in subsequent analysis stages. Generative AI tools were not used in any other stage of the study.

4. Logical Architecture of Results Transmission

The results transmission phase can be described as a set of flows among (i) collection points (polling stations), (ii) communication infrastructure, (iii) aggregation/reception nodes, and (iv) central tabulation and auditing systems. In this study, a reference logical architecture is adopted, composed of:

- **Source**: local systems that generate the results file and associated evidence (e.g., signatures and logs).
- **Transmission client**: component responsible for packaging, signing, encrypting, and transmitting results, including retransmission and contingency logic.
- **Transport**: secure links and tunnels (e.g., VPN/TLS) between the source and reception.
- **Reception and aggregation**: services that authenticate, verify integrity, register evidence, and forward data for tabulation.
- **Tabulation and auditing**: central systems, evidence repositories, audit trails, and monitoring services.

The main **trust boundaries** are located: (a) between the controlled local environment and the telecommunications infrastructure; (b) between the transport layer and reception services; and (c) between reception/aggregation services and central tabulation/auditing systems. These boundaries guide the application of STRIDE, as they delimit points where identity, integrity, and authorization must be revalidated.

5. Critical Assets and Requirements

Based on the architecture, the critical assets include: results files and evidence; cryptographic keys and administrative credentials; reception and tabulation services; audit trails; communication channels; and contingency mechanisms (queues, temporary storage, and retransmission). Critical requirements are guided by the following pillars:

- **Integrity**: ensuring that results and evidence are not altered, inserted, or suppressed without detection; this requires digital signatures, integrity verification, and verifiable audit trails [Panja and Roy 2021, Chatterjee et al. 2023].
- **Availability**: ensuring transmission and reception within defined time windows, while resisting failures and denial-of-service attacks; this requires redundancy, contingency capacity, and monitoring [Akinsanya 2025, Masi et al. 2023].
- **Confidentiality**: protecting keys, credentials, and operational metadata that could expose infrastructure or enable improper inference; this requires key protection, metadata minimization, and privilege segregation [Cortier et al. 2024, Gjosteen et al. 2023, Hirschi et al. 2021].

Table 4 summarizes the assets/channels and their predominant critical pillars (Integrity/Availability/Confidentiality).

Asset / Channel	Integrity	Availability	Conf.
Results files + evidence (signatures, proofs)	Cr	–	Cr
Private keys, certificates, and administrative credentials	Cr	–	Cr
Transmission client (packaging, encryption, retransmission)	Cr	Cr	Cr
Tunnels and links (VPN/TLS, routing)	Cr	Cr	Cr
Reception/aggregation service (validation, logging, queues)	Cr	Cr	–
Evidence repository and audit trails	Cr	–	Cr
Tabulation and results dissemination service	Cr	Cr	–
Monitoring, detection, and incident response	–	Cr	–

Table 4. Assets/channels and critical pillars (Cr = critical; – = relevant but not prioritized).

6. Threat Modeling with STRIDE

This section applies the STRIDE model to the data flow diagram developed in *Excalidraw* [Excalidraw Team 2024] for a results transmission system. The diagram was built from a theoretical model of the Brazilian electronic election system and infrastructure for the transmission phase, covering the main components, integrations, and trust boundaries typically observed in this context. In particular, the model represents a *pipeline* centered on a collector/orchestrator component, responsible for receiving, validating, and forwarding result artifacts, integrating internal services of the Electoral Justice system and cloud services.

The architecture depicted in the diagram highlights the traversal of multiple *trust boundaries* (internal environment, Internet, and cloud provider), as well as synchronous (request/response) and asynchronous (queue/events) flows associated with ingestion, persistence, and publication of files. These elements directly influence the attack surface. They also guide the STRIDE analysis by revealing sensitive points, including: authentication and authorization across domains; protection of credentials and tokens; integrity and traceability of artifacts and metadata; access policies for cloud storage; and resilience against unavailability or service abuse.

Although inspired by the Brazilian scenario and an evolving proposal within the Electoral Justice context for cloud-assisted file transmission, the model is deliberately generic. Thus, the threats and controls discussed are applicable, with minimal adaptations, to other electoral arrangements and different election types that rely on a *pipeline* for transmitting, validating, persisting, and querying results.

The analysis was guided by the *trust boundaries* made explicit in the diagram (Internet, the Electoral Justice private network, and public *cloud*), as well as by synchronous request/response flows (HTTPS) and the asynchronous flows that compose the processing *pipeline*.

6.1. Scope and trust boundaries

The diagram (Figure 1) represents a *cloud-assisted* architecture for results transmission, structured around a **collector/orchestrator** component that integrates internal services and managed cloud services. Three main trust boundaries are observed: (i) the **user/operator** access edge (browser) through a distribution layer (e.g., CDN) to the Web interface; (ii) the **APIs and authorization** boundary (authentication, domain, and *upload* endpoints) mediated by an *API Gateway* and an *authorizer*; and (iii) the **managed cloud services** boundary, including object storage (S3), a NoSQL database for metadata and tokens

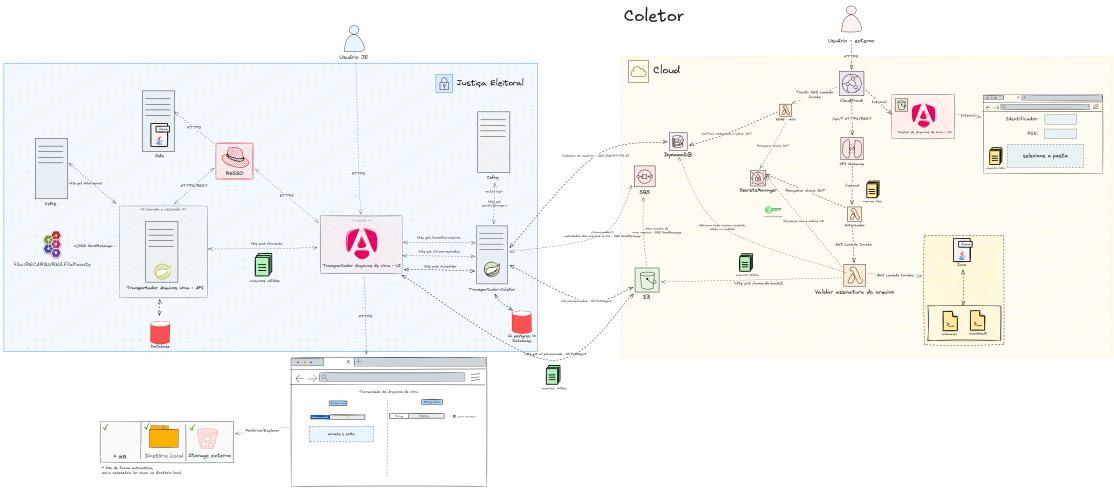

Figure 1. Diagram (cloud architecture) for results transmission, including components, integrations, and trust boundaries.

(DynamoDB), messaging (SQS), and secrets management (Secrets Manager).

In the operational *pipeline*, synchronous (request/response) flows stand out for authentication, token issuance and validation, and file upload/query; and asynchronous (queue/events) flows for notification and downstream processing. Therefore, the attack surface is strongly influenced by: (a) identity and session mechanisms in the *frontend*; (b) scope-based authorization and cryptographic token validation in the *authorizer*; (c) integrity and traceability of artifacts (results file) and their metadata; and (d) IAM policies and cloud service configurations that determine exposure, isolation, and resilience.

The following were considered critical assets: (a) the *results media* and its derived artifacts; (b) provenance and state metadata (e.g., processing trail, *timestamps*, and identifiers); (c) identities, credentials, secrets, and tokens (including keys/*claims* and session parameters); and (d) event/queue messages associated with notification and orchestration. The prioritized security properties were: integrity of content and metadata; availability of the transmission/query *pipeline*; confidentiality of credentials, tokens, and secrets; and traceability/auditability to support non-repudiation and forensic analysis.

6.2. STRIDE threat catalog

Tables 5 and 6 consolidate the threats identified from the diagram, organized into *edge* (access via CDN/*frontend*), *API* (API Gateway and *authorizer*), *compute* (validation, storage, and metrics functions/Lambdas), and *data/messaging* (S3, DynamoDB, and SQS) layers. Threats were derived considering boundary crossings, the centrality of the token as the authorization mechanism, and the dependence on managed cloud services, whose configurations (IAM, bucket policies, encryption, quotas, and logs) are decisive for exposure and resilience.

7. Discussion and Practical Implications

The results of this study should be interpreted in light of the characteristics of computer networks and distributed systems. Unlike centralized scenarios, electoral results transmission takes place over a distributed infrastructure. This infrastructure is subject to variable latency, partial node failures, dependence on cloud providers, and dynamic traffic conditions—phenomena also observed in fault-tolerance studies of distributed environments

ID	Component/Flow	Threat (description)	Mitigations (summary)
Spoofing (identity impersonation)			
S1	User/Browser → CDN/Frontend	Session hijacking, *phishing*, or credential theft enables actions (upload/query) on behalf of a legitimate operator.	MFA; OIDC/OAuth2; short-lived tokens; *step-up auth*; anomaly detection.
S2	Frontend → API Gateway (endpoints)	Token reuse/forgery (or leaked token) enables unauthorized access to upload and query endpoints.	Strict JWT validation (aud/scope/exp); revocation; WAF; *rate limiting*.
S3	API Gateway → Authorizer (Lambda)	Unverified service identity enables *service spoofing* and authorization bypass.	Dedicated authorizer; cryptographic verification; role segregation; *deny-by-default*.
S4	Lambdas → S3/DynamoDB/Secrets Manager	Compromised service credentials enable unauthorized access to data, files, and secrets.	Least-privilege IAM; per-function roles; rotation; Secrets Manager; anomalous behavior alerts.
Tampering (integrity violation)			
T1	UploadController → ValidationService	File modification before/during validation compromises the integrity of the transmitted result.	Digital signature; verified hash; format validation; authenticated channel.
T2	StorageService → S3 (objects)	Replacement/overwrite or *object poisoning* alters stored artifacts.	Versioning; Object Lock (WORM) when applicable; KMS; non-predictable keys; hash-based validation.
T3	Metadata → DynamoDB	Manipulation of status/origin/*timestamps* compromises chain of custody and enables fraud.	*Server-side* validation; conditional writes; auditing; per-table IAM.
T4	SQS → Asynchronous processing	Message injection, modification, or reordering triggers unauthorized processing.	Payload signature/HMAC; schema validation; idempotency; DLQ; *replay* protection.
Repudiation (non-repudiation and traceability)			
R1	Endpoints (auth/domain/upload/query)	Lack of correlatable audit trail enables denial of upload, query, and state changes.	Correlated logs (*request-id*); trusted timestamping; retention; immutable trail.
R2	Token issuance/validation	Lack of traceability in token issuance/use hinders attribution and incident response.	Authentication logs; centralized auditing; metrics and alerts; end-to-end tracing.
R3	Messaging (SQS)	Without producer/consumer tracing, parties may deny event publication or processing.	Producer identity; *message tracing*; per-queue metrics; consumption/*ack* evidence.

Table 5. Threats identified from the diagram (cloud architecture), organized by STRIDE: Spoofing, Tampering, and Repudiation.

with delays and timing failures in real networks [Oliveira et al. 2025]. In this context, threats such as denial of service, in-transit interception, and loss of synchronization among components are not merely theoretical hypotheses. They represent plausible operational risks that directly affect the availability and integrity of the electoral process.

Making trust boundaries and critical assets explicit enables the alignment of technical controls (cryptography, authentication, monitoring, and contingency mechanisms) with electoral objectives of reliability, timeliness, and auditability. Because the STRIDE approach is structured and repeatable, it promotes consistent documentation and communication between technical teams and governance bodies, which is particularly relevant in regulated environments. As a limitation, the catalog is synthetic: it describes classes of threats but does not replace the analysis of implementation-specific scenarios (e.g., key management, network architecture, provider contracts) that may alter likelihood and impact.

7.1. Synthesis of the main modeling findings

The analysis suggests that the most relevant risks concentrate at points where **identity, authorization, and integrity must be revalidated**: (i) user access to the distributed interface (CDN/*frontend*) and session maintenance; (ii) token issuance, storage, and verification (authentication endpoints and the *authorizer*); (iii) persistence and querying of artifacts and metadata in managed services (S3 and DynamoDB); and (iv) triggering of asynchronous processing via messaging (SQS). In these transitions, *Spoofing* and *Elevation of Privilege* threats may enable unauthorized access to routes and data, while *Tampering*

ID	Component/Flow	Threat (description)	Mitigations (summary)
Information Disclosure (information exposure)			
I1	S3 (results files)	Inadequate ACL/IAM policies expose files (or allow unauthorized listing/download).	Block Public Access; principal-scoped IAM; KMS encryption; continuous review (CSPM).
I2	DynamoDB (metadata/tokens)	Excessive permissions expose metadata and tokens, expanding the surface for *replay* and abuse.	Least-privilege IAM; encryption; environment segregation; monitoring and alarms.
I3	Logs/telemetry	Leakage of tokens, URLs, IDs, or sensitive data in logs/errors.	Redaction; minimization; log levels; access control; limited retention.
I4	Secrets Manager/parameters	Secret exposure due to misconfiguration, broad permissions, or pipeline *leaks*.	Secrets vault; automatic rotation; restrictive policies; secret scanning; auditing.
Denial of Service (unavailability)			
D1	CDN/Frontend	Request flooding degrades the interface and prevents legitimate transmissions.	WAF; *rate limiting*; CDN/cache; edge autoscaling.
D2	API Gateway/Authorizer	Endpoint or authorizer saturation blocks authentication and upload.	Throttling; quotas; *circuit breakers*; controlled degradation; monitoring.
D3	SQS	Backlog/*poison messages* increase latency and block asynchronous processing.	DLQ; backpressure; consumer scaling; idempotency; payload validation.
D4	DynamoDB/S3	Throughput exhaustion affects persistence and querying of metadata/files.	Capacity planning; autoscaling; caching; quotas; monitoring.
D5	Cloud provider (managed services)	A sovereignty/jurisdiction-driven cloud shutdown disrupts API, validation, and storage, causing full unavailability of the collection pipeline.	Exit plan and failover to a national cloud provider; object/metadata replication; DNS/route switchover; IaC to rebuild services; store-and-forward; regular game days with RTO/RPO.
Elevation of Privilege (privilege escalation)			
E1	Authorizer/IAM	Overly permissive IAM policies enable escalation and access beyond the required scope.	Least privilege; permission boundaries; continuous review; policy-as-code.
E2	Internal Lambdas	Functions with privileged identity may be abused to perform administrative actions.	Role segregation; least privilege; approvals; audit trails.
E3	API Gateway (authorization)	Authorization flaws enable unauthorized access to privileged routes.	RBAC; *deny-by-default*; authorization testing; per-endpoint scopes.

Table 6. Threats identified from the diagram (cloud architecture), organized by STRIDE: Information Disclosure, Denial of Service, and Elevation of Privilege.

directly affects the chain of custody by allowing manipulation of files, events, or metadata. In addition, *Denial of Service* at edge layers (CDN), *API Gateway/authorizer*, and the *data plane* (S3/DynamoDB/SQS) may degrade pipeline timeliness, with operational and reputational effects.

7.2. Controls and mitigation strategies

From an engineering perspective, key controls include **end-to-end integrity** mechanisms (signatures, hashes verified at multiple points, format and schema validation, conditional writes for metadata, and idempotency in message consumption), **strong identity and authorization** (OIDC/OAuth2, an *authorizer* with strict JWT validation, RBAC based on *scopes*, and least-privilege IAM with *permission boundaries*), and **observability** (correlatable logs, end-to-end tracing, auditing of authentication and data access, anomaly detection, and alerting). For availability, **resilience** mechanisms such as WAF, rate limiting/throttling, quotas, circuit breakers, DLQs, and backpressure reduce the risk of saturation and message accumulation, especially during transmission peaks. For managed storage and databases, encryption (KMS), restrictive access policies, versioning/*immutability* when applicable, and continuous configuration monitoring (CSPM) are recommended to mitigate *Information Disclosure* and *Tampering* associated with misconfigurations.

Asset	Critical properties	STRIDE	Vector/observation in the diagram
Results media (file)	I, A, C	T, I, D	Upload/query via Frontend/*API Gateway* and persistence in S3; risk of modification, leakage, and artifact unavailability.
File metadata (status, version, origin, trail)	I, Non-repudiation	T, R	Metadata persistence/query in DynamoDB; risk of tampering to break chain of custody and lack of correlatable auditing.
Pre-signed URL / *signed URL*	C, Non-repudiation	S, I, R	Token issuance/use/validation at endpoints and in the *authorizer*; risk of *replay*/improper reuse and attribution difficulty without authentication trails.
Credentials and tokens (users/services)	C, I	S, E, I	Authentication at *controllers* and service-to-service calls; risk of session hijacking, identity spoofing, and privilege escalation.
Profiles and roles (RBAC/ACL)	I, Non-repudiation	T, E, R	Management via authentication/authorization services and policies (IAM/RBAC); risk of role changes, *broken access control*, and lack of change traceability.
Event messages (SQS/AMQP)	I, A, Non-repudiation	T, D, R	Asynchronous integration with Event Listener/Outbox; risk of message injection/tampering, *backlog*, and repudiability without end-to-end correlation.
Logs and audit trails	Non-repudiation, I, C	R, T, I	Required for non-repudiation and forensics; risk of absence, manipulation, or leakage of secrets/URLs/sensitive data in logs.
Application APIs (*controllers/services*)	A, I	D, E, T	Primary attack surface; risk of *flooding*, abuse of privileged endpoints, and malicious inputs propagating to DB/queues.
DynamoDB (metadata/tokens)	A, I, C	D, T, I, E	Central dependency for metadata and queries; risk of connection/*lock* exhaustion, tampering, and unauthorized access by over-privileged accounts.
Cloud storage (S3/DynamoDB/SQS)	C, I, A	I, T, D, E	Policies/IAM and encryption keys determine exposure and integrity; risk of broad permissions, isolation failures, and provider unavailability.

Table 7. Mapping between assets, critical properties, and STRIDE categories in the modeled system.

7.3. Implications for electoral auditing and governance

STRIDE-based modeling facilitates the translation of technical risks into verifiable audit requirements. *Repudiation* and *Tampering* threats require evidence of audit trails and chain of custody (trusted timestamps, event correlation, and consistent records), whereas *Spoofing* and *Elevation of Privilege* inform identity controls, segregation of duties, and credential management. In practice, the catalog can support test plans, change acceptance criteria, monitoring requirements, and evidence packages for compliance assessments.

7.4. Illustrative application scenario

Consider a scenario in which the aggregation service uses pre-signed URLs to transfer partial results in a cloud environment under a misconfigured access control policy. Under these conditions, a malicious actor may capture and reuse the URL within its validity period, characterizing a replay attack, associated with the Tampering and Repudiation categories.

In the proposed catalog, this vector is associated with the "transmission channel" asset and with the trust boundary between the local node and the cloud infrastructure, being mitigated by controls such as short token expiration, binding to IP addresses or devices, and detailed audit logging.

Based on this mapping, specific requirements (e.g., maximum validity of X minutes), test cases (simulation of URL reuse), and audit procedures (verification of logs and IAM policies) can be derived, illustrating the practical applicability of the catalog in operational environments.

7.5. Limitations

This study is based on a reference logical architecture and a representational DFD; therefore, the identified threats and mitigations should be interpreted as *classes of risks* rather than an assessment of a specific deployed election infrastructure. The actual likelihood and impact of each threat depend on implementation-specific choices (protocols, key management, telecommunications design, *cloud* configurations, operational procedures, and access policies).

Because the analysis is qualitative and architecture-driven, it does not provide quantitative risk scoring, performance evaluation under peak load, or empirical validation via implementation artifacts (e.g., configuration assessment, penetration testing, red teaming, or incident-driven coverage comparison). Likewise, the bibliometric step supports topic organization and requirement rationale, but it does not substitute for a systematic mapping of the catalog to real incidents or to a formally verified set of controls. Despite these limitations, the approach is useful for structuring risk coverage, making trust boundaries explicit, and guiding requirements, test planning, and the definition of audit evidence for the transmission stage.

8. Conclusion and Future Work

This paper presented a threat modeling study for the results transmission phase in electronic elections, structuring a reference logical architecture, critical assets and requirements, and a synthetic STRIDE-based threat catalog. As future work, we recommend: (i) detailing attack scenarios per asset, with explicit severity criteria; (ii) validating the catalog through testing and exercises (e.g., availability simulations and audit trail verification); and (iii) mapping controls to normative frameworks and auditing procedures to enhance traceability and verifiability.

References

Agência Brasileira de Inteligência (ABIN) (2025). Desafios de inteligência: edição 2026. *Desafios de Inteligência: edição 2026*. Accepted: 2025-12-01T12:11:16Z.

Akinsanya, A. (2025). Security by design: a risk-based framework for cybersecurity compliance and critical infrastructure protection. *INTERNATIONAL JOURNAL OF INFORMATION SECURITY*, 24(6).

Albert Mondong, W., Yasa, R., Hadiprakoso, R., and Setia Buana, I. (2024). Design and Development of a Blockchain-Based Digital Diploma Verification System Using the STRIDE Threat Model Approach: A Case Study at Pusdatin of Ministry XYZ. In *Proc. - Int. Conf. Informatics, Multimed., Cyber Inf. Syst. ICIMCIS*, pages 972–977. Institute of Electrical and Electronics Engineers Inc. Journal Abbreviation: Proc. - Int. Conf. Informatics, Multimed., Cyber Inf. Syst. ICIMCIS.

Angganegara, M., Mukti, I., and Fathinnuddin, M. (2025). Integration of STRIDE and MITRE ATT&CK Frameworks for Enhanced Cyber Threat Modeling: A Case Study of Digital Merchant Banking Application. In *ICADEIS - Int. Conf. Adv. Data Sci., E-learning Inf. Syst.: Integr. Data Sci. Inf. Syst., Proceeding*. Institute of Electrical and Electronics Engineers Inc. Journal Abbreviation: ICADEIS - Int. Conf. Adv. Data Sci., E-learning Inf. Syst.: Integr. Data Sci. Inf. Syst., Proceeding.

Aria, M. and Cuccurullo, C. (2017). bibliometrix : An R-tool for comprehensive science mapping analysis. *Journal of Informetrics*, 11(4):959–975.

Bhole, M., Sauter, T., Semper, S., and Kastner, W. (2025). Why to Fail Fast and Often: A Strategy for OT Safety and Security Evaluation. *IEEE ACCESS*, 13:51793–51812.

Chatterjee, U., Ray, S., Adhikari, S., Khan, M. K., and Dasgupta, M. (2023). Efficient and secure e-voting scheme using elliptic curve cryptography. *SECURITY AND PRIVACY*, 6(3):e283. _eprint: https://onlinelibrary.wiley.com/doi/pdf/10.1002/spy2.283.

Cortier, V., Gaudry, P., and Yang, Q. (2024). Is the JCJ voting system really coercion-resistant? In *2024 IEEE 37th Computer Security Foundations Symposium (CSF)*, pages 186–200.

De Faveri, C., Moreira, A., Araújo, J., and Amaral, V. (2016). Towards security modeling of e-Voting systems. In *2016 IEEE 24th international requirements engineering conference workshops (REW)*, pages 145–151. IEEE.

Excalidraw Team (2024). Excalidraw+ | Collaborative workspace made simple.

{FBI} and {CISA} (2024). Just So You Know: Ransomware Disruptions during Voting Periods Will Not Impact the Security and Resiliency of Vote Casting or Counting.

Gjosteen, K., Haines, T., and Solberg, M. (2023). Coercion Mitigation for Voting Systems with Trackers: A Selene Case Study. In Volkamer, M., Duenas-Cid, D., Rønne, P., Ryan, P., Budurushi, J., Kulyk, O., Rodriguez Pérez, A., and Spycher-Krivonosova, I.-K., editors, *Lect. Notes Comput. Sci.*, volume 14230 LNCS, pages 69–86. Springer Science and Business Media Deutschland GmbH. Journal Abbreviation: Lect. Notes Comput. Sci.

Hirschi, L., Schmid, L., and Basin, D. (2021). Fixing the Achilles Heel of E-Voting: The Bulletin Board. In *2021 IEEE 34th Computer Security Foundations Symposium (CSF)*, pages 1–17.

Koitmae, A., Willemson, J., and Vinkel, P. (2021). Vote Secrecy and Voter Feedback in Remote Voting – Can We Have Both? In Krimmer, R., Duenas-Cid, D., Volkamer, M., Duenas-Cid, D., Kulyk, O., Rønne, P., Solvak, M., and Germann, M., editors, *Lect. Notes Comput. Sci.*, volume 12900 LNCS, pages 140–154. Springer Science and Business Media Deutschland GmbH. Journal Abbreviation: Lect. Notes Comput. Sci.

Lencse, A. A.-A. G. (2020). *Towards the identification of the possible security issues of the 464XLAT ipv6 transition technology*. IEEE.

Lueks, W., Querejeta-Azurmendi, I., and Troncoso, C. (2020). VOTEAGAIN: A scalable coercion-resistant voting system. In *Proceedings of the 29th Usenix Security Symposium*, pages 1553–1570, Berkeley. Usenix Assoc. Num Pages: 18 Web of Science ID: WOS:000668146200088.

Masi, M., Sellitto, G., Aranha, H., and Pavleska, T. (2023). Securing critical infrastructures with a cybersecurity digital twin. *SOFTWARE AND SYSTEMS MODELING*, 22(2):689–707.

Olaf Saßnick, Rosenstatter, T., Schäfer, C., and Huber, S. (2024). STRIDE-based Methodologies for Threat Modeling of Industrial Control Systems: A Review. In *2024 IEEE 7th International Conference on Industrial Cyber-Physical Systems (ICPS)*, pages 1–8.

Oliveira, V. R., Oliveira, J. M., Macedo, D., and Nogueira, J. M. (2025). Tolerância a Falhas com Aprendizado por Reforço para Tomada de Decisão em Cenários Distribuídos. In

Simpósio Brasileiro de Redes de Computadores e Sistemas Distribuídos (SBRC), pages 71–83. SBC.

Panja, S. and Roy, B. (2021). A secure end-to-end verifiable e-voting system using blockchain and cloud server. *Journal of Information Security and Applications*, 59.

R Core Team (2025). R: A Language and Environment for Statistical Computing.

Risnanto, S., Rahim, Y., Mohd, O., Kusmadi, u., Effendi, A., and Perdana, R. (2021). E-Voting: Security, Threats and Prevention. In *Proceeding Int. Conf. Telecommun. Syst., Serv., Appl., TSSA*. Institute of Electrical and Electronics Engineers Inc. Journal Abbreviation: Proceeding Int. Conf. Telecommun. Syst., Serv., Appl., TSSA.

Ryan, A., Geel, O. V., Pennings, F., Tirtea, R., and Follmer, V. (2019). Election cybersecurity: Challenges and opportunities. Opinion Paper 03, European Union Agency for Network and Information Security (ENISA), Athens, Greece.

Sarker, A., Byun, S., Fan, W., Psarakis, M., and Chang, S.-Y. (2020). Voting Credential Management System for Electronic Voting Privacy. In *IFIP Netw. Conf. Workshops, Netw.*, pages 594–598. Institute of Electrical and Electronics Engineers Inc. Journal Abbreviation: IFIP Netw. Conf. Workshops, Netw.

Shostack, A. (2014). *Threat Modeling: Designing for Security*. John Wiley & Sons. Google-Books-ID: YiHcAgAAQBAJ.

Silva, C., Oliveira, C., and Andrade, R. (2025). MARIA: Monitoramento e Análise para Resposta Imediata a Ataques à Rede 5G no Contexto da IoT. In *Simpósio Brasileiro de Redes de Computadores e Sistemas Distribuídos (SBRC)*, pages 364–377. SBC.

U.S. Congress (2023). Critical infrastructures protection. Sec. 5195c. In *THE PUBLIC HEALTH AND WELFARE. Title 42*. U.S. Government Publishing Office, 2023 edition.

Zhu, R., Wu, X., Sun, J., and Li, Z. (2021). Research on Smart Home Security Threat Modeling based on STRIDE-IAHP-BN. In *2021 20th International Symposium on Distributed Computing and Applications for Business Engineering and Science (DCABES)*, pages 207–213.